

Analisi Dinamica: DanaBot Banking Trojan

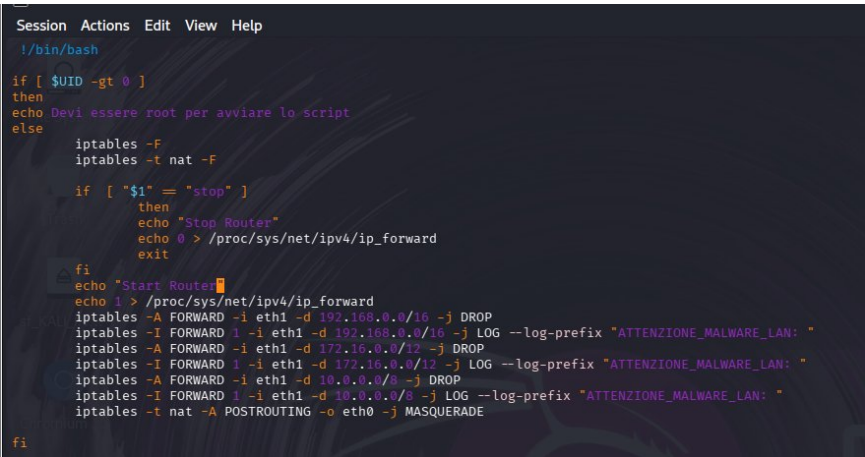
Corso Cybersecurity & Ethical Hacking — EPICODE Institute of Technology | 03 Giugno 2026

1. Introduzione

In questo lab ho condotto un'analisi dinamica del campione DanaBot, un banking trojan modulare attivo dal 2018. L'analisi e' stata condotta in un ambiente isolato e controllato: la macchina FlareVM su VirtualBox ha eseguito il campione, mentre Kali Linux ha operato come gateway con iptables configurato per bloccare il traffico verso reti private. Gli strumenti utilizzati sono stati Process Monitor, Process Explorer e FakeNet-NG 3.5 su FlareVM, e Wireshark su Kali per la cattura del traffico di rete.

2. Ambiente di analisi

Ho configurato Kali Linux come router/gateway per FlareVM tramite uno script iptables che abilita il forwarding IP e applica regole di sicurezza per contenere il malware.



```
Session Actions Edit View Help
!/bin/bash

if [ $UID -gt 0 ]
then
echo Devi essere root per avviare lo script
else
iptables -F
iptables -t nat -F

if [ "$1" = "stop" ]
then
echo "Stop Router"
echo 0 > /proc/sys/net/ipv4/ip_forward
exit
fi
echo "Start Router"
echo 1 > /proc/sys/net/ipv4/ip_forward
iptables -A FORWARD -i eth1 -d 192.168.0.0/16 -j DROP
iptables -I FORWARD 1 -i eth1 -d 192.168.0.0/16 -j LOG --log-prefix "ATTENZIONE_MALWARE_LAN: "
iptables -A FORWARD -i eth1 -d 172.16.0.0/12 -j DROP
iptables -I FORWARD 1 -i eth1 -d 172.16.0.0/12 -j LOG --log-prefix "ATTENZIONE_MALWARE_LAN: "
iptables -A FORWARD -i eth1 -d 10.0.0.0/8 -j DROP
iptables -I FORWARD 1 -i eth1 -d 10.0.0.0/8 -j LOG --log-prefix "ATTENZIONE_MALWARE_LAN: "
iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
fi
```

Fig. 1 — Script iptables su Kali: masquerading su eth0, blocco forwarding verso reti private e logging ATTENZIONE_MALWARE_LAN.

Macchina	IP	OS	Ruolo
FlareVM	192.168.50.150	Windows 10	Esecuzione DanaBot, Procmon, FakeNet-NG, Process Explorer
Kali Linux	192.168.50.100	Debian-based	Gateway iptables, Wireshark, whois

3. Setup strumenti di analisi

Prima di eseguire DanaBot ho configurato gli strumenti di monitoring su FlareVM. Ho avviato Process Explorer per il monitoraggio dei processi in tempo reale e Procmon con filtro su DanaBot.exe per catturare esclusivamente le operazioni del processo maligno.

Process Start	PID 2392, figlio di PID 4768	Avvio del processo DanaBot
Load Image	ntdll.dll, wow64.dll, wow64cpu.dll	Binario 32-bit su sistema 64-bit
RegQueryValue	HKLM\System\CurrentControlSet\...	Fingerprinting ambiente/sandbox
RegQueryValue	HKLM\SOFTWARE\Policies\Microsoft\...	Verifica policy di sicurezza
Process Create	conhost.exe PID 6912	Spawn processo per process injection
CreateFile	C:\Users\FlareVm\AppData\Local\Temp\	Deposito file temporanei

5. Analisi traffico di rete con Wireshark

Ho catturato il traffico su Kali con filtro `ip.addr == 192.168.50.150`. Ho identificato connessioni verso molteplici server C2 su porta 443 con TLSv1.2.

No.	Time	Source	Destination	Protocol	Length	Info
1095	510.648273688	192.168.50.150	172.178.240.163	TLSv1.2	259	Application Data
1096	510.648691968	192.168.50.150	172.178.240.163	TCP	1514	49898 → 443 [ACK] Seq=563 Ack=4569 Win=64189 Len=1460
1097	510.648892919	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [ACK] Seq=4569 Ack=2823 Win=65535 Len=0
1098	510.649259724	192.168.50.150	172.178.240.163	TLSv1.2	2719	Application Data
1099	510.649447882	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [ACK] Seq=4569 Ack=3483 Win=65535 Len=0
1100	510.649490193	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [ACK] Seq=4569 Ack=4688 Win=65535 Len=0
1101	510.650162955	192.168.50.150	172.178.240.163	TLSv1.2	569	Application Data
1102	510.650335223	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [ACK] Seq=4569 Ack=5203 Win=65535 Len=0
1103	510.876743329	172.178.240.163	192.168.50.150	TLSv1.2	1027	Application Data
1104	510.878214046	192.168.50.150	172.178.240.163	TCP	60	49898 → 443 [FIN, ACK] Seq=5203 Ack=5542 Win=63216 Len=0
1105	510.878579131	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [ACK] Seq=5542 Ack=5204 Win=65535 Len=0
1106	511.056256229	172.178.240.163	192.168.50.150	TCP	54	443 → 49898 [FIN, ACK] Seq=5542 Ack=5204 Win=65535 Len=0
1107	511.056584273	192.168.50.150	172.178.240.163	TCP	60	49898 → 443 [ACK] Seq=5204 Ack=5543 Win=63216 Len=0
1108	511.187277406	192.168.50.150	51.77.7.204	TCP	60	[TCP Retransmission] 49897 → 443 [SYN] Seq=0 Win=6424
1109	511.611592312	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1367)
1110	511.631882691	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1380)
1111	513.109981137	192.168.50.150	51.77.7.204	TCP	60	[TCP Retransmission] 49897 → 443 [SYN] Seq=0 Win=6424
1112	513.639731813	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1113	513.660063777	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1114	515.688395354	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1115	515.709550887	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1116	517.125031229	192.168.50.150	51.77.7.204	TCP	60	[TCP Retransmission] 49897 → 443 [SYN] Seq=0 Win=6424
1119	517.717570619	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1120	517.730874413	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1121	519.749679428	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1122	519.770337541	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1123	521.798723367	192.168.50.150	8.8.8.8	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1124	521.819081895	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1125	523.832192456	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) request id=0x1739, seq=0/0, ttl=64 (reply in 1371)
1126	523.852391879	8.8.8.8	192.168.50.150	ICMP	98	Echo (ping) reply id=0x1739, seq=0/0, ttl=254 (request in 1371)
1127	525.144764136	192.168.50.150	51.77.7.204	TCP	60	[TCP Retransmission] 49897 → 443 [SYN] Seq=0 Win=6424

Fig. 5 — Wireshark: prima connessione C2 riuscita verso 172.178.240.163:443 (TLSv1.2) e tentativi verso 51.77.7.204:443.

Fig. 6 — Wireshark avanzato: molteplici IP C2 identificati, Keep-Alive verso 52.58.157.118:443 e 64.233.167.188:5228.

IP C2	Porta	Proto	ASN/Proprietario	Paese	Stato
172.178.240.163	443	TLSv1.2	Microsoft Azure (AS8075)	US	Connessione riuscita
51.222.39.81	443	TCP	Non gestito RIPE	EU	RST/ACK — rifiutato
51.77.7.204	443	TCP	OVH SAS (AS16276)	FR	Retransmission continua
52.58.157.118	443	TCP	Amazon AWS	DE	Keep-Alive attivo


```
{"get_panels":1,"get_login_urls":1,"product":"dntme","tag":"default",  
"browser":"Chrome","user_state":"unregistered",  
"client_application":{"version":"2.21.0.5015","environment":"production",  
"product":"DNT3","device":"Extension","device_id":"3241655783"}}
```

7. Indicatori di Compromissione (IOC)

Tipo IOC	Valore
Processo C2	rundll32.exe usato come proxy per connessioni C2
Processo iniettato	conhost.exe (figlio di DanaBot.exe)
IP C2 attivi	172.178.240.163, 52.58.157.118, 64.233.167.188
IP C2 tentativi	51.77.7.204, 51.222.39.81, 149.255.35.125, 51.178.195.151, 38.68.50.179
Porta C2	443 (TLSv1.2)
Identificatore prodotto	dntme (campo JSON beacon C2)
Versione modulo	2.21.0.5015
Chrome Extension ID	caljgklbbfbcjjanaijlacgncafpegll
Device ID	3241655783
Endpoint C2	/api/v2/mappings/manifest

8. Conclusioni

L'analisi dinamica di DanaBot ha confermato la natura modulare e sofisticata di questo banking trojan. Ho verificato l'uso di process injection in rundll32.exe e conhost.exe per nascondersi tra i processi di sistema, fingerprinting del registro per rilevare sandbox, e utilizzo di infrastruttura cloud legittima (Azure, AWS) per i C2. Il beacon C2 intercettato da FakeNet ha rivelato la versione 2.21.0.5015 del modulo Chrome, che richiede al pannello di controllo la lista degli URL bancari da monitorare tramite web inject.

Le misure difensive consigliate: monitoraggio connessioni in uscita da rundll32.exe verso porta 443; rilevamento di conhost.exe con parent process inattesi; ispezione TLS in uscita tramite proxy; blocco estensioni Chrome non autorizzate.